

W2-PM4

WEEK 2 | PROJECT MODULE 4



Cybersecurity



Ethical Hacking

For educational purposes only!

FOOTPRINTING & RECONNAISSANCE WITH theHARVESTER

CYBERSECURITY & ETHICAL HACKING PROJECT TASKS

WEEK 2 | PROJECT MODULE 4

FOOTPRINTING & RECONNAISSANCE ATTACKS WITH theHARVESTER

Background

theHarvester is a footprinting tool which is used for gathering information of emails, sub-domains, hosts, employee names, open ports and banners from different public sources like search engines, PGP key servers and SHODAN computer database. It has been developed in Python.

theHarvester comes pre-installed in Kali Linux. Simply, just start it using commands shown in this lab.

What we will do in this module?

In this module, we will learn how to gather the list of email IDs related to a target organization using theHarvester tool.

TASKS

Task 1. Find email IDs & sub-domains related to a target organization microsoft.com using the theHarvester tool in Kali Linux with Baidu. Set the limit of number of results to 1000.

Task 2. Find email IDs & sub-domains related to a target organization microsoft.com using the theHarvester tool in Kali Linux with all sources. Set the limit of number of results to 50.



TASK 1

SOLUTION

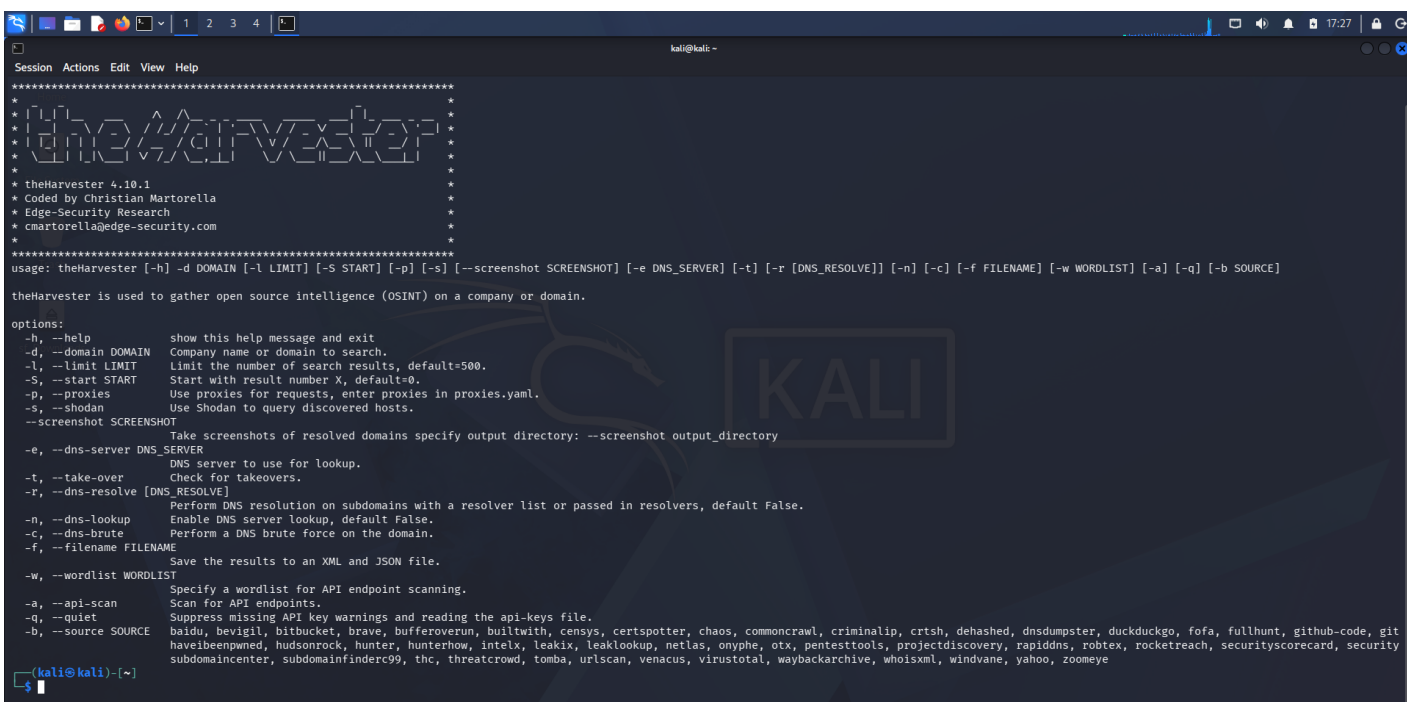
STEP 1

Open theHarvester tool in Kali Linux from the menu:



STEP 2

Read the usage instructions & guidelines:



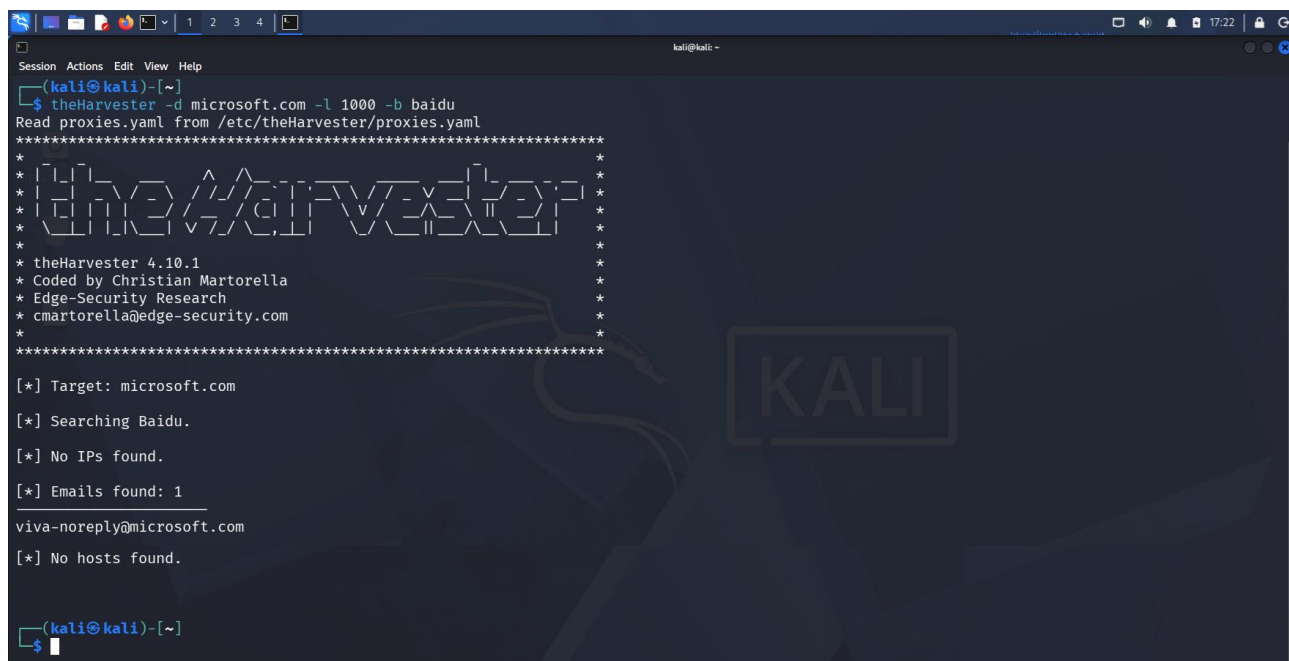
* Guideline shows that currently these sources are supported:

baidu, bevigil, bitbucket, brave, bufferoverrun, builtwith, censys, certspotter, chaos, commoncrawl, criminalip, crtsh, dehashed, dnsdumpster, duckduckgo, fofa, fullhunt, github-code, git, haveibeenpwned, hudsonrock, hunter, hunterhow, intelx, leakix, leaklookup, netlas, onyphe, otx, pentesttools, projectdiscovery, rapiddns, robtex, rocketreach, securityscorecard, security, subdomaincenter, subdomainfinder99, thc, threatcrowd, tomba, urlscan, venacus, virustotal, waybackarchive, whoisxml, windvane, yahoo, zoomeye

STEP 3

In the terminal windows, type below command to start theHarvester & search for the required detail using Baidu:

```
$ theHarvester -d microsoft.com -l 1000 -b baidu
```



```

kali@kali: ~
$ theHarvester -d microsoft.com -l 1000 -b baidu
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
*                                     *
* theHarvester 4.10.1                 *
* Coded by Christian Martorella        *
* Edge-Security Research               *
* cmartorella@edge-security.com        *
*                                     *
*****

[*] Target: microsoft.com
[*] Searching Baidu.
[*] No IPs found.
[*] Emails found: 1
viva-noreply@microsoft.com
[*] No hosts found.

kali@kali: ~
$

```

Here -d is the target domain, -l limits the number of results, and -b sets the data source. theHarvester then extracts the details and shows them on screen. Scroll down to see the emails and hosts.



Note: Your results might be a bit different than shown here in this lab because theHarvester is based on other information sources which keep on changing their algorithms time to time. Therefore, the search results might be a bit different but the search methods remain the same.

STEP 4

Save the screenshot.
Save the output in a text file.

```

*****
*
* THE HARVESTER
*
* TheHarvester Ver. 4.10
* Coded by Christian Martorella
* Edge-Security Research
*****

```

SOLUTION

STEP 1

Click here to open a new terminal window

STEP 2

```
$ theHarvester -d microsoft.com -l 50 -b all
```

```

kali@kali:~$ theHarvester -d microsoft.com -l 50 -b all

Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
*                                     *
* theHarvester                       *
*                                     *
* theHarvester 4.10.1                *
* Coded by Christian Martorella      *
* Edge-Security Research              *
* cmartorella@edge-security.com      *
*                                     *
*****

[*] Target: microsoft.com

Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to process bevigil search for word: 'microsoft.com'
Error Message:
[!] Missing API key for bevigil.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml

[!] Missing API key for Bitbucket.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to process bufferoverun search for word: 'microsoft.com'
Error Message:
[!] Missing API key for bufferoverun.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to perform BuiltWith search for word: 'microsoft.com'
A Missing Key Error occurred in builtwith:
[!] Missing API key for BuiltWith.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Failed to process brave search for word: 'microsoft.com'
Error Message:
[!] Missing API key for Brave Search.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml

```

STEP 3

Save the screenshot.
Save the output in a text file.

WHY FOOTPRINTING WITH THEHARVESTER MATTERS?

theHarvester collects emails, sub-domains and hosts from dozens of public sources without ever touching the target directly. Each harvested email is a possible target for phishing and password attacks. Each sub-domain is another door into the organization that a defender may have forgotten about. Because the tool only reads public data, the target never knows it is being studied, which is exactly why this kind of passive recon is so powerful and so hard to detect. Defenders run the same tool on themselves to see what an attacker would see, and then reduce what they leak.



Extra References & tips

- ☐ theHarvester is passive recon: it reads public sources and never touches the target.
- ☐ Different data sources return different results, so always try more than one.
- ☐ Harvested emails feed phishing campaigns; sub-domains expand the attack surface.
- ☐ The less an organization exposes publicly, the harder every later attack stage becomes.
- ☐ theHarvester comes pre-installed in Kali Linux but if you are using other OS then you can install it using the command: `sudo apt-get install theHarvester`. If this does not work you can clone the Git hub repository and use it using commands:

```
$git clone https://github.com/laramies/theHarvester.git
```

```
$cd theHarvester
```

```
$sudo python ./theHarvester.py
```



Liability Disclaimer



These materials are for education and research purpose only. Although this course includes practicals and labs, but they are meant for learning purposes only. The aim is to show you how attacks work in real world systems so you can defend systems better. Do not use anything from here to break the law. The instructor, the authors and Networkwalks are not responsible for what you do with this knowledge. Every action you take is your own responsibility. Misuse can lead to criminal charges, heavy fines, loss of your job and a permanent record. In most countries unauthorised access is a crime even when nothing is damaged.

Hacking is only legal when:

- You test a device or network that you own or your Lab environment
- You have written and documented permission from the owner
- You are working as a security professional under a signed agreement with an agreed scope

Everything outside these cases is illegal!

Virtual lab

Your own devices



By continuing you confirm that you have read this disclaimer and accept full responsibility for your actions!



© All Rights are reserved, Networkwalks

Contact us today for your Cybersecurity & Network consultancy or your next training course & certification on Cisco CCNA, Cybersecurity, Ethical Hacking, Python programming, Linux & AI.

 +27 766 222 218 | +27 788 220 600

Leave your feedback at: info@networkwalks.com. Your technical questions, comments & suggestions are always Welcomed.